

Chapter 1 – Architectural Concepts

Existing State – evaluate and understand the business processes, assets, and requirements; after collecting sufficient data, a detailed analysis is necessary; a BIA (business impact analysis) takes place

- **BIA (Business Impact Analysis):** an assessment of the priorities given to each asset and process within the organization; analysis considers the effect (impact) any hard or loss might mean to the organization overall; identify critical paths and single points of failure; determine costs of compliance (legislative and contractual requirements mandated)
- **Metered service:** the organization only pays for what it uses
- **Rapid Elasticity:** excess capacity available to be apportioned to cloud customers
- **Cloud bursting:** organizations to use hosted cloud service to augment internal, private data center capabilities with managed services during times of increase demand; an org can rent the additional capacity as needed from an external cloud provider (crisis situation, heavy holiday shopping periods); rapid scalability allows customer to dictate the volume of resource

Cloud service benefits – reduction in personnel cost (data management); reduction in capital expenditure (metered service, rapid elasticity, cloud bursting; reduction in operational costs; transferring some regulatory costs; reduction in costs for data archival/backup services

- **ROI (Return on Investment):** term related to cost-benefit measures; used to describe a profitability ratio; calculated by dividing net profits by net assets
- **Elasticity:** customers can contract cloud providers to use virtualization to flexibly allocate only the needed usage of each resource to the organization, while holding costs while maintaining profitability; allow users to access their data from diverse platforms and locations, increasing portability, accessibility, and availability
- **Simplicity:** allows a user to seamlessly use the service without frequently interacting with the cloud service provider
- **Scalability:** increasing/reducing services can be easily, quickly, and cost-effectively accomplished

Cloud Computing Service Models

- **IaaS (Infrastructure as a Service):** most basic service; allows customer to install all software and OSs on hardware housed and connected by the cloud vendor; can be considered a warm site for BC/DR purposes; optimal for orgs wanting control over the security of their data and limited cloud vendor assistance (BC/DR or archiving); least expensive option; customer retain IT staffing
 - o When to use: website or application hosting; virtual data centers; data analysis
- **PaaS (Platform as a Service):** includes services from IaaS and OSs (offers a selection for customers to use, Windows, Linux, Mac, etc.); vendor is responsible for patching, administering, and updating the OS; customer can install any software; useful for customers involved in software development (they can test on multiple OS platforms); includes cloud-based database engines and services “big data” style services (data warehousing and data mining); provider offers access to back-end engine/functionality, while customer can create/install apps/APIs to access the backend

- When to use: reduce development time; support for different programming languages; easy collaboration for remote/distributed teams; high development capabilities w/o additional staff
- Data Storage Types used: structured/unstructured
- **Unstructured Data Types:** qualitative data; natural-language text; incorporate media (audio, video, images); contains JSON, XML, binary objects (images encoded as text strings); important for data analytic strategies; noSQL
- **Structured Data Types:** quantitative data; organized and decipherable by machine learning algorithms; SQL (relational) can be used to quickly input, search, and manipulate data; used by machine learning algorithms
- **SaaS (Software as a Service):** includes everything from IaaS and PaaS with the addition of software programs; vendor is responsible for administering, patching, and updating everything, also takes care of all infrastructure, compute, and storage needs as well as providing OSs and application; customer is only involved in uploading and processing data on a full production environment; application is a shared responsibility of all parties
 - When to use: (Personal) email services (Gmail), cloud storage services (Dropbox), cloud-based file management (Google Docs); (Business) Gmail, collaboration tools (Trello), CRM (Salesforce), ERP

Cloud Deployment Models

- **Public Cloud:** resources are owned and operated by a vendor and sold, leased, or rented to anyone; multitenant environments; multiple customers will share resources; EX: customer might be using a VM that resides on the same hardware that hosts another VM as their competitor, but they do not know the entities using the same resources; Rackspace, Microsoft's Azure, and AWS (Amazon Web Services)
- **Private Cloud:** resources dedicated to a single customer; might be owned and maintained by the entity that is the sole customer (org might own and operate a data center that serves as the cloud environment for the org's users); might be a set of resources (racks, blades, software packages) owned by the single customer but located and maintained at provider's data center; provider might offer physical security, admin services, and utilities (power, Internet) for customers (referred to as co-lo (co-located) environment)
- **Community Cloud:** features infrastructure and processing owned and operated by/for an affinity group; orgs come together to perform joint tasks and functions; gaming communities, ownership is spread throughout the various members of the community; can be provisioned by a third party (FedRAMP service – only used by US federal gov)
- **Hybrid Cloud:** contains elements of other models; org might want to retain some private cloud resources (remote user access) but lease some public cloud space (PaaS function for software development/testing)

Roles/Responsibilities

- **Cloud Broker:** a company that purchases hosting services from a provider and resells them to its own customers

- **CASB (Cloud Access Security Broker):** third-party entity offering independent IAM (identity and access management) services to CSPs and cloud customers; can be SSO, certificate management, and cryptographic key escrow
- **Regulators:** ensure orgs are in compliance with regulatory framework for which they are responsible for; **HIPAA, GLBA, PCI DSS, ISO, SOX**, etc.; regulators include FTC, SEC, and auditors

Definitions

- **Cost-Benefit Analysis:** comparing potential positive impact (profit, efficiency, market share) of a business decision to potential negative impact (expense, detriment to production, risk) and weighing the two as equivalent or not (potential positive/negative)
- **FIPS 140-2:** NIST document that describes the process for accrediting and cryptosystems for use by the federal government; lists only approved cryptographic tools
- **NIST 800-53:** guidance document with primary goal of ensuring appropriate security requirements and controls are applied to all US federal government information in management systems
- **TCI (Trusted Cloud Initiative) Reference Model:** guide for cloud providers, allowing them to create a holistic architecture that customers can purchase (including physical/logical layout of network and processes necessary to utilize both)
- **Vendor Lock-In:** situation where a customer is unable to leave, migrate, retrieve, or transfer data to an alternate provider due to technical/nontechnical constraints; use portability for a level of ease when transporting data, ensure contract states so, avoid proprietary formats (requires specific software to read data), check for regulatory constraints; detrimental contract terms or technical limitations.
- **Vendor Lock-Out:** when a customer is unable to recover/access their own data due to provider going into bankruptcy or leaving the market.
- **Blockchain:** open means of conveying value using encryption technologies/algorithms (cryptocurrency); transactional ledger where all participants can view every transaction, making it extremely difficult to negatively affect the integrity of past transactions; each record (block) is distributed among all participants in a distributed or cloud-based manner
- **Containers:** logical segmentation of memory space in a device, creating two or more abstract areas that cannot interface directly; commonly used in BYOD environment; distinguish two distinct partitions (one for work functions/data and other for personal functions/data)
- **Quantum Computing:** emerging technology that allow IT systems to operate beyond binary math; instead of using the presence of electrons for calculations (electrons is either present/not present), quantum computing may use subatomic characteristics (electron spin, charm, etc.) to offer computing on exponentially larger scale
- **Homomorphic Encryption:** theoretical phenomenon that allow processing of encrypted material without needing to first decrypt it; can allow cloud customers to upload encrypted data and still utilize data without sharing keys with provider or having to accommodate decryption as part of the process
- **STRIDE Threat Model:** Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, and Elevation of Privilege
- **Apache cloud stack:** open source cloud computing software for creating, managing, and deploying infrastructure cloud services; uses existing hypervisor platforms

- **Business Requirement:** operational driver for decision-making and input for risk management

Chapter 2 – Design Requirements

Business Requirements Analysis – inventory of all assets; valuation of each asset (BIA, data owners determine value; head of department); determination of critical paths (made by senior management; SPOFs), processes, and assets; clear understanding of risk appetite (set by senior management)

SPOFs (Single Points of Failure) methods to reduce – adding redundancies; creating alternative processes; cross-training personnel; back up data; load sharing/balancing for IT assets

- Quantitative Risk Assessment: use specific numerical values such as 1,2, and 3; employ a set of methods, principles, or rules for assessing risk
- Qualitative Risk Assessment: use nonnumerical categories that are relative in nature; high, medium, and low; employ a set of methods, principles, or rules for assessing risk
- Risk: likelihood an impact will be realized; can be reduced, never eliminated; orgs can accept a level of risk that allows operations to continue in a successful manner; legal and defensible to accept risks higher than the norm/greater than your competitors (except risk to health and human safety, must be addressed to industry standard/regulatory scheme)

There are four main ways to address risk

- **Avoidance:** risk that exceeds the organization's appetite; leaving business opportunity because risk is too high and cannot be compensated for with adequate control mechanisms; response to cost-benefit analysis; don't conduct the risk at all; halts business functions
- **Acceptance:** opposite of avoidance; falls within the org's risk appetite; org continue operations without any additional efforts
- **Transference:** org pays someone else to accept the risk, at a lower cost (insurance); normally with low probability of occurring but a high impact if they do
- **Mitigation:** org take steps to decrease the likelihood/impact of the risk; form of controls/countermeasures, where security practitioners are involved
- **Residual Risk:** when risks are mitigated by applying countermeasures and controls the remaining leftover risk is residual risk; task of security program is to reduce until it falls within the acceptable level according to org's risk appetite (senior management dictates the appetite)

Security Considerations for Cloud – the cloud customer is always legally liable for any loss of data, even if cloud provider demonstrates negligence or malice

- IaaS Considerations – customer has the most responsibility and authority; provider is responsible for building, land, connectivity, power, and hardware assets; makes auditing difficult because they cannot set up network monitoring for policy and regulatory compliance, but customers can collect and review event logs from the software (OS too)
- PaaS Consideration – same as IaaS but provider controls the OSs; customer can still monitor and review software events because the programs running on the OS belongs to them
- SaaS Consideration – customer only supplies and process data; security controls are limited because provider supplies all needs of customer

- To demonstrate due care – ensure cloud provider performs strict background checks, continual monitoring of all personnel with access to data center, extreme physical security measures, encryption of data processed and stored, assignment of contractual liability to the provider, etc.

Chapter 3 – Data Classification

Data Ownership: assign responsibilities according to who has possession and legal ownership of that data; roles are assigned to allocate this

- **Data Owner:** org that collected/created the data; usually department head/business unit manager; cloud customer is usually the data owner (international treaties/frameworks refer to as the data controller)
 - o Data owners remain legally responsible for all data they own
- **Data Custodian:** person or entity tasked with the daily maintenance/administration of the data; role of proper security controls and processes as directed by the data owner; sometimes a database admin
- **Data Processor:** any org or person who manipulates, stores, or moves the data on behalf of the data owner; cloud provider is a data processor (international law)
 - o Data processors do not necessarily all have direct relationships with data owners; processors can be third parties or further removed down the supply chain

Data Lifecycle – understand it in order (Create > Store > Use > Share > Archive > Destroy)

- **Create:** data owner will be identified in this first phase; data security and management responsibilities require action; data owner will categorize the data
- Data Categorization:
 - o **Regulatory Compliance:** can categorize by specific datasets (GLBA, PCI, SOX, HIPAA, GDPR, other international, national, and local compliance)
 - o Business Function: different use of data (billing, marketing, operations)
 - o Functional Unit: department or office with its own category and data controls
 - o By Project: define datasets by projects associated with as means of creating discrete, compartmentalized projects
 - o **Data Classification:** responsibility of the data owner; assigned by the org's policy based on characteristics of dataset
 - Sensitivity: used by the US military; assigned to the sensitivity of the data, based on negative impact an unauthorized disclosure would cause
 - Jurisdiction: geophysical location of the source/storage point of the data might determine how the data is handled; PII gathered from citizens from EU is subject to the EU privacy laws
 - Criticality: data deems critical to org survival classified in a manner distinct from trivial, basic operational data; BIA helps determine this
 - o **Data Mapping:** data between organizations (or departments) normalized and translated so it is meaningful to both parties; in classifications, mapping is necessary so data that is sensitive must be protected in one org must be recognized by the receiving org
 - o **Data Labeling:** when data owner creates, categorizes, and classifies the data, it also must be labeled; should indicate who the data owner is (office or role, not name or identity); should take any form to be enduring, understandable, and consistent; Ex:

labels on hardcopy data might be printed headers/footers, labels on electronic files might be embedded in the filename/nomenclature; labels should be evident and communicate pertinent concepts without disclosing data they describe; labels may include:

- Date of creation; Date of scheduled destruction/disposal; Confidentiality level; Handling directions; Dissemination/distribution instructions; Access limitations; Source; Jurisdiction; Applicable regulation

- **Data Discovery:** used to refer several kinds of tasks to determine and accurately inventory the data under its control; org is attempting to create an initial inventory of data it owns, org is involved in electronic discovery (e-discovery), and can modern the use of datamining tools to discover trends and relations in the data already in the org's inventory
 - **E-Discovery:** legal term for how electronic evidence is collected as part of an investigation/lawsuit
- **Label-Based Discovery:** labels created will aid in any data discovery efforts; org can determine what data it controls and amounts of each kind; labels are useful when the discovery effort is undertaken in response to a mandate with specific purpose (court order/regulatory demand); can easily collect and disclose all appropriate data if labeled
- **Metadata-Based Discovery:** data about data, a listing of traits and characteristics about specific data elements/sets; can be useful for discovery purposes; data discovery uses metadata the same way as labels to scan field for particular terms for certain purposes
- **Content-Based Discovery:** discovery tools can be used to located and identify specific kinds of data by delving into the content of datasets (even without labels/metadata); basic term searches or sophisticated pattern-matching technologies

Data Analytics: technological options to provide additional findings and assigning types to data; modern tools create new data feeds from sets of data that already exist within the environment; modes used are real-time analytics, datamining, and agile business intelligence

- **Datamining:** an outgrowth of the possibilities offered by regular use of the cloud (big data); when org collects data streams and run queries across the feeds, the org can detect and analyze previously unknown trends and patterns that can be useful
- **Real-Time Analytics:** tools can provide datamining functionality concurrently with data creation and use; the tools rely on automation and require efficiency to perform properly
- **Agile Business Intelligence:** state-of-the-art datamining involves recursive, iterative tools and processes that can detect trends and identify more oblique patterns in historical and recent data

Jurisdictional Requirements

- United States: address privacy with industry-specific legislation (GLBA for banking/insurance, HIPAA for medical care, etc.) or with contractual obligations (PCI); granular data breach notification laws exist that are enforced by states and localities (New York/California); strong protections for intellectual property
- Europe: has massive, exhaustive, comprehensive personal privacy protections (EU General Data Protection Regulation); good intellectual property protection
- Asia: data privacy protection levels differ by country; with its Act on the Protection of Personal Information, Japan and Singapore adheres to the EU model, China has a legal requirement the

opposite of privacy (all IT traffic and communications in China must be accessible by the Chinese government); disparate levels of intellectual property protection

- South/Central America: most countries lack privacy protection frameworks; Argentina is an exception; their Personal Data Protection Act is in direct correlation with the EU legislation; has various intellectual property mechanisms
- Australia/New Zealand: has the Australian Privacy Act mapping directly to the EU statutes; provide strong intellectual property protections and strong privacy protections

IRM (Information Rights Management) – managing information in accordance with who has rights to it; can be **DRM** (digital/data rights management), ERM (enterprise); uses a variety of tools to enforce intellectual property rights such as support-based licensing, local agent enforcement, and media-present checks

Intellectual Property Protections – intangible; assets of the mind

- Copyright: legal protection for expressions of ideas; in the US, granted to anyone who first creates an expression of an idea (literary works, films, music, software, and artistic works); does not cover ideas, specific words, slogans, recipes, formulae; lasts for 70 years after the author's death/120 years after the first publication of a work for hire; creator is the only entity legally allowed to do the following: perform the work publicly, profit from the work, make copies of the work, make derivative works from the original, import or export the work, broadcast the work, sell/assign the rights
- Trademarks: intended to be applied to specific words and graphics; representations of an org – its brand; can be the name of an org, logo, phrase, color, sound, or combo of these
- Patents: legal mechanism for protecting intellectual property in the form of inventions, processes, materials, decorations, and plant life; lasts about 20 years from time of patent application
- Trade Secrets: has same aspects as patented material (processes, formulas, commercial methods, etc.); includes aggregations of information (list of clients/supplies)

IRM Tool Traits – material protected by IRM solutions need some form of labeling/metadata associated with the material for the IRM tool to function properly

- Rudimentary Reference Checks: content itself can check for proper usage/ownership; Ex: vintage games will pause in operation until player entered information acquired with the purchase of a licensed copy of the game (word/phrase from manual shipped with game)
- Online Reference Checks: Microsoft software packages (Windows OS/Office programs) requiring product key at installation; program will check against online database when connected to the Internet
- Local Agent Checks: user installs reference tool that checks the protected content against the user's license; Ex: Steam when installing games purchased, agents check user's system against online license database to ensure games are not pirated
- Presence of Licensed Media: disks for example, is required to be present when the content is being used; IRM engine is on the media, often installed with a cryptographic engine that identifies the unique disk and the licensed content and allowing usage based on that relationship

- Support-Based Licensing: predicted on the need of continual support for content (production software); vendor can prevent unlicensed versions from getting support (updates/patches)

IRM in the Cloud Complications

- Replication Restrictions: IRM often prevent unauthorized duplication, the cloud may create, close, and replicate virtualized host instances; IRM might interfere with automatic resource allocation processes
- Jurisdictional Conflicts: cloud extends across boundaries and borders, often pose problems when intellectual property rights are restricted by locale.
- Agent/Enterprise Conflicts: IRM solutions that require local installation of software agents for enforcement purposes might not always function properly in the cloud environment, virtualization engines, or various platforms used in BYOD enterprise
- Mapping IAM (Identity and Access Management) and IRM: the extra layer of access control (ACLs) will cause a conflict between IRM IAM and enterprise/cloud IAM; more possible if these functions are outsourced to a third party (CASB)
- API Conflicts: IRM tool is often incorporated into the content, usage of material might not offer the same level of performance across different applications (content readers/media players)

IRM Functions Provided (regardless of type of content/format)

- Persistent Protection: follow the content it protects regardless of location, if it's duplicated or original file, or how it's being utilized
- Dynamic Policy Control: should allow content creators and data owners to modify ACLs and permissions for the protected data under their control
- Automatic Expiration: because of the nature of legal protections of intellectual property, a significant amount of digital content will not be protected in perpetuity; protection should cease when legal protections cease; licenses also expire, access and permissions for protected content should expire
- Continuous Auditing: allow for comprehensive monitoring of the content's use and access history
- Replication Restrictions: purpose of IRM is to restrict illegal or unauthorized duplication of protected content; IRM solutions should enforce restrictions across the many forms of copying that exist (screen-scraping, printing, electronic duplication, email attachments)
- Remote Rights Revocation: owner of rights to intellectual property should have ability to revoke rights at any time; used because of litigation/infringement

Data Control – protect data other than in the CREATE lifecycle phase; each aspect of data management (retention, audit, disposal) will need a specific policy addressing it

Data Retention Policy

- Retention Periods: length of time organization should keep data; data being archived for long-term storage, reduce data footprint, reduce duplicate data; not being used in production; expressed in number of years, set by regulation/legislation; can be mandated/modified by contractual agreements

- Applicable Regulation: can be mandated by statute/contract; policy should refer to all applicable regulatory guidance
- Retention Formats: contain description of how data is actually archived (type of media storage, handling specifications); Ex: some types of data are required to be encrypted while in storage, policy should include description of encryption engine, key storage and retrieval procedures, and reference to regulation(s).
- Data Classification: org can use classification level of data to determine how long specific datasets/types of data need to be retained
- Archiving and Retrieval Procedures: mandate the creation of a detailed description of the processes both for sending data into storage and recovery; usually attach to policy or mentioned by reference, usually kept separate
- Monitoring, Maintenance, and Enforcement: list in detail how often it will be reviewed, amended, by whom, consequences for failure to adhere to policy, and which entity is responsible for enforcement
- Legal Hold: supersede org's retention/destruction policies; when law enforcement/regulatory/private entity is commencing litigation against the org, they must suspend all relevant data destruction activities until fully resolved (only relevant data); concept is dictated by the Federal Rules of Evidence (HIPAA); considered temporary paramount retention period

Data Audit – org need to regularly review, inventory, and inspect usage and condition of data it owns; should have policy for conducting audits and include audit periods; scope; responsibilities (internal/external); processes/procedures; applicable regulations; monitoring, maintenance, and enforcement; audit is predicated on logging (event; security; traffic); data audit policy addresses activities that take place in all phases of the data lifecycle

Data Destruction/Disposal – because of the cloud environment, hardware destruction or overwriting storage area is nearly impossible; **crypto-shredding will be the sole pragmatic option for data disposal in the cloud**; must include in the policy the process for data disposal, regulations, clear directions of when data should be destroyed; addresses activities in the DESTROY phase of data lifecycle

- **Crypto-Shredding (Cryptographic Erasure)**: encrypt the data with a strong encryption engine, take the keys generated and encrypt them with a different encryption engine, then destroying the resulting keys of the second round of encryption

Chapter 4 – Cloud Data Security

Data Lifecycle: Create > Store > Use > Share > Archive > Destroy

Create– defines classification levels

- Data created remotely – data created by the user should be encrypted before uploading to the cloud; protects against MIIM attacks/insider threats at cloud data center; connection should be secure too (IPsec or TLS VPN solution)
- Data created within the cloud – should be encrypted upon creation; allows both read and process functions to be performed

Store – usually refer to near-term storage; this phase will happen when the data is created (occurs simultaneously); encryption at rest/transit should happen before this phase begin

Use – platforms used to connect to data in the cloud needs to be secure (VPN, IRM, DLP); for BYOD, a holistic approach should be used; data owners should restrict permissions; logging and audit trails are important when data are manipulated; on provider's side, strong protections should be implemented, ensure virtualized data can't be read/detected by other hosts on the same device

Share – craft sharing restrictions based on jurisdiction; limit/prevent data being sent to certain locations (export/import controls); implement some form of egress monitoring; uses content delivery networks

- Export/Import Restrictions
 - o ITAR (International Traffic in Arms Regulations – US): State department prohibit defense-related exports (includes cryptography systems)
 - o EAR (Export Administration Regulations – US): Department of Commerce prohibits dual-use items (technologies used for both commercial/military purposes)
 - o Cryptography (Various): many countries restrict on importing cryptosystems/materials that has been encrypted
 - o The Wassenaar Arrangement: group of 41 members have agreed to mutually inform each other about conventional military shipments to nonmember countries; not a treaty, not legally binding, may require org to notify government to stay within compliance

Archive – phase for long-term storage; cryptography is the essential consideration; key management is important, if lost, can lead to exposure or total loss; weigh in the risk of physical security (location, format, staff, procedure)

Destroy – crypto shredding is the only feasible and thorough means available

Cloud Storage Architectures

Volume Storage: customer is allocated storage space; represented as an attached drive to user's VM; can take forms of file-based/block storage/raw disk storage; includes bit splitting and erasure coding, a means of implementing data protection solutions similar to RAID arrays; often associated with IaaS; user/admin can install/run programs

- Threats: since it's a drive space, all traditional data storage threats remain; malware, deletion of data, and physical disk failure; since data is stored in the cloud, MiiM exists
- **Block Storage**: provides low latency and high-performance values; useful for structured storage; blank volume customer can put anything into; allow more flexibility and higher performance, requires greater amount of administration, installation of an OS or app to store, sort, and retrieve the data; better suited for a volume and purpose that includes data of multiple types and kinds (enterprise backup services)
- **File Storage** (File-Level Storage/File-Based Storage): data stored/displayed with a file structure in a traditional environment (files/folders) with same hierarchical and naming functions; popular with big data analytical tools/processes

Object-Based Storage: best used for large unstructured data when durability, unlimited storage, scalability, and metadata management are factors for overall performance; customers are given access to parts of the hierarchy; include actual production content, metadata describing the content/object, and unique address identifier for locating object across entire storage space; allow for significant level of description (marking, labels, classification, categorization); enhances opportunities for indexing capabilities, data policy enforcement (IRM, DLP), and centralization of data management functions; stores presentations, documents, audio files; usually associated with IaaS

- Threats: object storage doesn't have a runtime environment; risk of malware is reduced but parasitical viruses can infect specific files; loss due to physical disk failure; ransomware attacks

Ephemeral Storage: temporary resource used for processing; referred to as *instance store* volumes; provided by devices directly connected to a host machine; analogous to RAM for cloud VM

- Threats: data will be lost if VM instance is shut down or physical drive fails

Long-Term Storage: durable data storage capacity; offered at low cost and large amounts; used for archiving/backups; not used for production environments or installing/running programs; can run queries and analyze data stored

- Threats: insider threat; intermediary (MiiM attacks); ransomware; vendor lock-in

SAN (Storage Area Network): dedicated high-speed network that interconnects and deliver shared pools of storage devices on multiple servers

- **iSCSI:** makes it possible to set up a shared-storage network where multiple servers and clients can access central storage resources; creates a SAN

NAS (Network Attached Storage): remote storage accessed; hosted by 3rd party service provider

Databases – provide some structure for stored data; arranged according to characteristics and elements in the data itself (trait required to file the data know, primary key); usually backend storage in the data center, accessed by users utilizing online apps/APIs through a browser; PaaS and SaaS

CDN (Content Delivery Network): used for large amounts of data that require time-sensitive communication and low latency; a form of data caching, usually near geophysical locations of high use/demand, for copies of data commonly requested by users; Ex: online multimedia streaming services, improves bandwidth and delivery quality

- Threats: intermediaries; insider threats; malware

Cloud Data Security Foundational Strategies

Key Management – how and where encryption keys are stored can affect the risk of data; keys must be secured at the same level of control (level of protection); must have key recovery (usually multiple people with access to a portion of the key); key distribution; key revocation; key escrow (copies of keys by trusted third party); outsourcing key management

- HSM (Hardware Security Module): device that safely store and manage encryption keys; used in servers, data transmission, and log files; far stronger than saving/storing in software

Key Protection Methods: Masking, Obfuscation, Anonymization, and Tokenization

- When to use it?: Test environments; enforcing least privilege; secure remote access
- How to perform these activities?:
 - o **Randomization**: replace part/all of the data with random characters
 - o **Hashing**: one-way cryptographic function to create a digest of the original data
 - o **Shuffling**: using different entries from within the same data set to represent the data
 - o **Masking**: hiding data with useless characters; XXX-XX-1234
 - **DDM (Dynamic Data Masking)**: replace sensitive data in transit leaving original at-rest data unaltered
 - **SDM (Static Data Masking)**: permanently replaces sensitive data by altering data at rest
 - o **Nulls**: deleting raw data from display before represented or displaying null sets
- **Obfuscation**: the application of any of the above techniques to make the data less meaningful, detailed, or readable to protect the data; can be done in static/dynamic matter
- **Anonymization** (Deidentification): can be difficult, sensitive data must be recognized and marked as sensitive when created, determining sensitivity might not be simple since data is input into open fields; mark creates metadata which can be valuable to attackers
- **Tokenization**: practice of having two distinct databases: one with live, actual sensitive data; one with nonrepresentational tokens mapped to each piece of that data; user/program is authenticated by the token server; adds significant overhead but creates extra degree of security (relieve org dependence on encryption); placing sensitive data with unique identification symbols; a way of hiding or concealing sensitive data by representing it with unique identification symbols/addresses, retains essential information w/o compromising security

SIEM (security information and event management): goals implementation of SIEM are to centralize collection of log data; enhance analysis capabilities; dashboarding; automated response

Egress Monitoring (DLP) – examining data as it leaves the production environment (DLP – data loss, leak prevention, and protection); some major goals are, additional security; policy enforcement; enhanced monitoring; regulatory compliance; can be added to IRM tools to control intellectual property

Chapter 5 – Security in the Cloud

FIGURE 5.1 Responsibilities according to service model

	Infrastructure as a Service (IaaS)	Platform as a Service (PaaS)	Software as a Service (SaaS)
Security Governance, Risk & Compliance (GRC)			
Data Security			
Application Security			
Platform Security			
Infrastructure Security			
Physical Security			

Cloud Customer Responsibility

Shared Responsibility

Cloud Provider Responsibility

Private Cloud – distributed computing environment with only one customer

- Risks: personnel threats; natural disasters; external attacks; regulatory noncompliance; malware

Community Cloud – resources are shared and dispersed among an affinity group

- Risks: resiliency through shared ownership; shared costs; no need for centralized administration for performance and monitoring

Public Cloud – offer services to any entity that wants to become a cloud customer

- Risks:
 - o **Vendor Lock-In:** customer is unable to retrieve data; use portability for a level of ease when transporting data, ensure contract states so, avoid proprietary formats, check for regulatory constraints; detrimental contract terms or technical limitations
 - **Data Portability:** used to avoid lock-in; the ease of moving data from cloud provider to another
 - o **Vendor Lock-Out:** provider goes out of business, bought out by another business, or ceases operation

Hypervisor:

- **Type 1:** also called bare-metal/hardware hypervisor; resides on host machine as bootable software
- **Type 2:** software hypervisor; runs on top of the OS that runs on a host device
- **Guest Escape / VM Escape:** allow a user to leave their own virtualized instance; user will be able to access other virtualized instances on the same host, view, copy, or modify data stored, access host itself affecting all instances on the machine
 - o **Host Escape:** user can leave the host machine, accessing other devices on the network
- **VMI (Virtual Machine Introspection):** agentless means of ensuring VM's security baseline does not change by examining the physical address, network settings, and installed OS

- **NFV (Network Functions Virtualization)**: replacement of network appliance hardware with VMs; uses a hypervisor to run networking software and processes such as routing and load balancing

SDN (Software Defined Networking): approach to networking that uses software-based controllers or APIs to communicate with underlying hardware infrastructure and direct traffic on a network; allow network admins to perform the following:

- Reroute traffic based on current customer demand
- Create logical subnets without having to change any actual physical connections
- Filter access to resources based on specific rules or settings

Chapter 6 – Responsibilities in the Cloud

- SOC reports: part of the SSAE reporting format by the AICPA; recognized as being acceptable for regulatory purposes, specifically designed for SOX
 - o SOC 1: reports for the auditing of financial reporting instruments of a corporation; there are 2 subclasses (Type 1 and Type 2)
 - o SOC 2: report audits of any controls on an org's security, availability, processing integrity, confidentiality, and privacy
 - Type 1: not useful for determining security and trust of an org; only reviews the design of controls, not how they are implemented / maintained / functioned
 - Type 2: useful for getting true assessment of org's security posture; extremely detail, usually not shared unless NDA is signed
 - o SOC 3: reports designed to be shared with the public; "seal of approval"; has no data about the security controls, an assertion the audit was conducted and passed

Chapter 7 – Cloud Application Security

- **Forklifting**: moving an entire application to the cloud without significant changes; often self-contained stand-alone applications
- Cloud-Secure SDLC (Software Development Lifecycle):
 - o **Defining**: during this phase, the focus is to identify the business requirements of the application (accounting, database, or customer relationship management); describe aspects of the business needs; do not choose tools/technologies at this phase
 - o **Designing**: this phase begins to develop user stories (what user want to accomplish and how to do it), what the interface will look like, and will it require use/development of any APIs
 - o **Development**: phase where the code is written
 - o **Testing**: activities of initial penetration testing and vulnerability scanning against the application; use techniques/tools for both DAST (Dynamic application security testing) and SAST (static); at least two types of tests take place, functional and security testing
 - Functional testing: ensures the software performs whatever tasks it was intended for, completely and accurately, in a manner resistant to loss/interruption
 - Security testing: ensures whatever controls were included in the software are working effectively and accomplishing their purpose

- **Secure Operations:** phase begins when thorough testing is complete and environment is secure
- **Disposal:** when software reaches end of life or replaced by newer application, it must be securely disposed
- QA (Quality Assurance): management/inspection to reduce possibility of introducing errors or harming the end product
- **ISO/IEC 27034-1 Standards for Secure Application Development:** created an approach orgs can use for tracking security controls used in software; provides overview of application security that introduces definitive concepts, principles, and processes; describes two documents, ONF and ANFs
 - **ONF** (Organizational Normative Framework): framework for all components of application security controls and best practices cataloged and leveraged by the org
 - **ANF** (Application Normative Framework): subsets of ONF for each specific application; shares the applicable parts of the ONF needed to achieve an application's required level of security and level of trust desired
 - **ANF-to-ONF relationship is one-to-one, every application has an ANF that maps back to the ONF; ONF-to-ANF relationship is one-to-many, ONF has many ANFs, but AND has only one ONF**
- IAM (Identity and Access Management): about the people, processes, and procedures used to create, manage, and destroy identities
 - Identity Management: process where individuals are given access to system resources by associating user rights with a given identity
 - Provisioning: first phase of IM; each subject is issued a unique identity assertion (ex: user ID); during the process, user is given a password to authenticate the identity assertion
 - Access Management: part of the process that deals with controlling access to resources once they have been granted; identifies who a user is and what they are allowed to access, accomplished through authentication, authorization, policy management, federation, and identity repositories
 - Identity Repositories: store of information or attributes of identities
 - Directory Services: how identities and attributes are managed; X.500 and LDAP; Microsoft AD; Novell eDirectory; Metadata replication and synchronization
 - **Federated Identity Management (Federation):** used to manage identities across disparate orgs; a SSO for multiple orgs; two types of federation; web of trust and use of 3rd party identifier (CASB)
 - **Web of Trust Model:** each member of the federation has to review and approve each other member for inclusion; doesn't scale well, can be costly
 - **In a trusted third-party model of federation (CASB), each member organization outsources the review and approval task to a third party they all trust. This makes the third party the *identifier* (it issues and manages identities for all users in all organizations in the federation), and the various member organizations are the *relying parties* (the resource providers that share resources based on approval from the third party).**

- **SAML** (Security Assertion Markup Language): a federation standard; XML-based and consists of a framework for communication authentication, authorization or entitlement information, and attribute information across orgs; a means for users from outside orgs to be verified as authorized users
 - **SAML 2.0**: standard used to pass security assertions across the internet (user IDs and authenticating credentials)
- **WS-Federation**: uses the term realms in explaining its capabilities to allow orgs to trust each other's identity information across orgs
- **OAuth**: used in authorization with mobile apps; provides 3rd party applications limited access to HTTP services
- **OpenID Connect**: interoperable authentication protocol based on OAuth 2 specification; allows developers to authenticate users across websites and applications without having to manage us/pw
- **Stateful Packet Inspection**: allow firewalls to prevent inbound traffic from entering unless connection has been initiated from inside the network
- **WAFs (Web Application Firewall)**: deployed in addition to network firewall; protect specific web-based applications like PCI DSS; can protect against DoS/DDoS attacks; function at Layer 7 in OSI model
- **DAM (Database Activity Monitoring)**: protects the DB from unusual requests or activity; can be agent (host)/network based; function at Layer 7 in OSI model
- **API Gateways**: impose controls as an API proxy to not directly expose the API; implement access control; limit connections for bandwidth to be available for all applications (helps with internal DoS attack); API logging; gathering metrics from access logs; additional API security filtering; function at Layer 7 in OSI model
- **XML Gateway**: works around how sensitive data and services are exposed to APIs; software/hardware based and can implement types of DLPs
- **XACML (eXtensible Access Control Markup Language)**: attribute-based access control policy language or XML-based language, designed to express security policies and access requests to information; can be used for web services, digital rights management, enterprise security applications
- **APIs (Application Programming Interface)**: coding components that allow applications to communicate through web interface in a safe and secure manner; two types of APIs in cloud-based applications
 - **RESTful APIs (Representational State Transfer)**: relies on stateless, client-server, cacheable communications. It is a software architecture consisting of guidelines and best practices for creating scalable web service
 - Characteristics: low processing; uses simple URLs/URIs; not reliant on a single programming language; scalable; offers outputs in many formats (CVS, JSON); efficient
 - Situations where REST works well: when bandwidth is limited; stateless operations are used; caching is needed
 - **SCIM (System for Cross-domain Identity Management)**: open standard designed to manage user identity information; provides a defined schema for

- representing users and groups, and a RESTful API to run CRUD operations on those user and group resources
- **SOAP (Simple Object Access Protocol)**: protocol specification providing for the exchange of structured information or data in web services; works over other protocols like SMTP, FTP, and HTTP
 - Characteristics: standards-based; reliant on XML; highly intolerant of errors; slower; built-in error handling; more accurate
 - Situations where SOAP works well: asynchronous processing; format contracts; stateful operations
- **SDK (Software Developmental Kits)**: collection of software development tools in one installable package; facilitate creation of applications by having a compiler, debugger, and software framework; kit that facilitates usages of an API
- **TLS (Transport Layer Security)**: protocol to ensure privacy when communication between applications, servers, or client
- **SSL (Secure Socket Layer)**: same use as TLS, replaced by TLS
- **Whole-Instance Encryption (Whole-Disk)**: encrypt all system's data at rest in one instance
- **STRIDE Model**: standardized way of describing threats by their attributes; Spoofing, Tampering, Repudiation, Information disclosure, Denial of service, Elevation of Privilege
- **CSRF (Cross-Site Request Forgery)**: manipulates a logged-on user's browser to send a forged HTTP request along with cookies to force the victim's browser to generate a request that a vulnerable application thinks is a legitimate request from the user
- **White-Box Testing SAST (Static Application Security Testing)**: reviewing the source code
- **Black-Box Testing DAST (Dynamic)**: testing the program as it functions in runtime; source code is not reviewed; team use inputs and results of application itself as it's running
- **Application Orchestration**: when two or more applications must interact in order to successfully complete a business process/transaction; two approaches we can take:
 - Link elements of the applications directly, so out of one is input of another; can lead to additional problems; creating unnecessary dependencies, increasing difficulty of version control, testing
 - Abstract the functions of the applications so input/output can be handled distinctly from the way the programs work; often with another code/software; preferable option; known as application orchestration
- **Authentication**: confirms the identity assertion belongs to the entity presenting it

Chapter 8 – Operations Elements

- Industry service standard for uptime is *five nines* (99.999%), less than 6 downtime minutes a year
- **Conditioning**: involves adjusting the voltage on the line; includes surge protectors
- **Uptime Institute (UI)**: advisory org to publish standards related to data center redundancy in pursuit of continuous operations, matters related to IT services, and certifies data centers for compliance
 - Tier 1: simplistic with little to no redundancy and labeled *Basic Site Infrastructure*; lists minimum requirements for a data center; dedicated space for IT systems, UPS system for line conditioning and backup purposes, sufficient cooling systems to serve all critical

equipment, power generator for extended electrical outages with at least 12 hours of fuel to run the generator; useful for orgs to use as a backup, private cloud, cheaper to operate, a hot/warm/cold site

- Tier 2: named *Redundant Site Infrastructure Capacity Components*; good for orgs looking to operate in the public cloud environment and maintaining low overhead
- Tier 3: known as *Concurrently Maintainable Site Infrastructure*; has added benefit of multiple distribution paths; there are dual power supplied for all IT systems; critical operations can continue even if any single component is out of service
- Tier 4: *Fault-Tolerant Site Infrastructure* is premium data center offering; redundancy in both IT and electrical components; facility will feature automatic response capabilities for infrastructure control systems
- **TPM (Trusted Platform Module)**: specialized chip on a computer designed to secure hardware with integrated cryptographic keys; helps prove user's identity and authenticate devices; provide security against firmware and ransomware attacks
- **Tightly Coupled Cluster Storage**: all storage devices are directly connected to a shared physical backplane; confined to restrictive design parameters; enhance performance as it scales
- **Loosely Coupled Cluster**: allow greater flexibility; each node of the cluster is independent; logically connected and do not share same proximate physical framework

Resiliency: two general ways for disk data protection in a cloud storage cluster: RAID and data dispersion

- **RAID** (Redundant Array of Independent Disks): all data is stored across various disks known as *striping*; allows data to be recovered if one drive fails; in some schemes (0-10) parity bits are added to raw data to aid in recovery after a drive failure
- **Data Dispersion**: data is sliced into chunks (shards) that are encrypted with parity bits (erasure coding in cloud data dispersion) and written to various drives in the cloud cluster; the parity bits/erasure coding allows recovery of partial data lost by recreating the lost data from remaining data plus parity bits/erasure code; can be seen equivalent to RAID array in a cloud environment; often referred to as *bit splitting*; uses parity bits, data chunks, and encryption
- **SSMS** (Secret Sharing Made Short): method of bit splitting using 3 phases: encryption, using information dispersal algorithm, and splitting encryption key using secret sharing algorithm; fragments are signed and distributed to different cloud storage services

Chapter 9 – Operations Management

- **OS Logging**: integral toolsets for monitoring performance and events; set OS logs to alert admins when usage approaches a level of capacity utilization, performance degradation, CPU usage, memory usage, disk space, disk I/O timing (slow writing/reading to/from disk)
- ASHRAE Recommended Range for data centers:
 - Temperature: 64-81 degrees F
 - Humidity: Dew point 42-59 degrees F; 60% relative humidity
- **Maintenance Mode**: all operational instances are removed from the system/device before entering this mode; prevent all new logins; ensure logging is continued; begin enhanced logging
- **CI/CD** (Continuous Integration/Continuous Delivery): incorporates heavy use of automation to shorten software delivery pipeline; includes administrative and technical controls

- **ISO/IEC 20000-1, Information technology – Service Management:** defines a set of operational controls and standards orgs can use to manage IT services; used to manage ITSM using approaches of ITIL and ISACA COBIT framework
 - **ITSM (IT Service Management):** goal is to identify user needs, design IT service to meet those needs, deploy it, then enter a cycle of continuous improvements
- **BC/DR (Business Continuity and Disaster Recovery):**
 - **Business continuity** efforts are concerned with maintaining critical operations
 - **Disaster Recovery** efforts are focused on resumption of operations due to disaster
 - **Event:** unscheduled impact to operating environment; impact lasts three days or less, disasters last longer, an event can become a disaster
 - The most important planning and efforts is health and human safety; notification, evacuation, protection, and egress will need to be prioritized
 - **MAD (Maximum Allowable Downtime):** how long an interruption will stop operations; referred to as MTD (maximum tolerable downtime)
 - **MTTR (mean time to repair):** average amount of time it takes to repair a system/device that is down
 - **RTO (Recovery Time Objective):** BC/DR goal for recovery of operation, measured in time; must be less than the MAD
 - **RPO (Recovery Point Objective):** BC/DR goal for limiting loss of data from unplanned event, measured in time; example – org resumes critical operations at alternate operating site with last full backup (if they backup every day, RPO will be 24 hours), RPO for org will be loss of no more than one day's worth of data; tolerable/acceptable amount of data that might be lost due to an outage before severe consequences are experienced.
 - **RSL % (Recovery Service Level):**
 - **ALE (Annual Loss Expectancy):** amount an org should expect to lose annually based on any one type of incident; **$ARO \times SLE = ALE$**
 - **ARO (Annual Rate of Occurrence):** rate of occurrence of a specific event/incident
 - **SLE (Single Loss Expectancy):** amount of expected damage/loss from any single specific security incident
 - UPS should last long enough for graceful shutdown of affected system, can provide line conditioning, adjusting power to optimize for the devices it serves and smooth power fluctuations; battery backup should only be relied on to provide immediate and near-term power supply; longer power supply should be provided by generators (short-term contingency)
 - Generators: supply close to immediate power when utility electricity is interrupted and have automatic transfer switches (not a viable replacement for an UPS); **minimum of 12 hours of fuel for all generators**
 - Testing:
 - **Tabletop Testing:** essential participants work together at a scheduled time; InfoSec equivalent of role-playing games; least impact on production of testing alternatives

- **Dry Run:** whole org takes part in a scenario at a scheduled time; impacts productivity
- **Full Test:** entire org takes part in an unscheduled, unannounced practice scenario, performing full BC/DR activities; includes system failover, facility evacuation, used for detecting shortcomings in the plan; greatest impact on productivity

Chapter 10 – Legal and Compliance Part I

- **Criminal Law:** all legal matters where the government is in conflict with person, group, or org that violates statutes (state and federal legislated by lawmakers); includes federal court system; punishments can be monetary fines, imprisonment, death; enforcement is called prosecution
- **State Laws:** laws enacted by a state legislature; federal laws supersede this
- **Federal Laws:** laws that affect the entire country; issues of jurisdiction and prosecution are negotiated between law enforcement and course prior to prosecution
- **Civil Law:** body of law, statutes, and so on that deals with personal and community-based law such as marriage/divorce; set of rules that govern private citizens and disputes; parties involved are strictly private entities; cases are called lawsuits/litigations; has restitution of monetary damages or perform actions but not imprisonment
- **Contracts:** agreement between parties; in a breach of contract, a party within the agreement can sue to get court-ordered relief in money or other considerations (property or other agreements made before); SLAs / PCI DSS contracts
- **Common Law:** existing set of rulings/decisions made by courts, informed by cultural mores and legislation; this creates precedents, each party will cite in course as means to sway the court
- **Administrative Law:** laws not created by legislatures but by executive decisions and function; federal agencies can create, monitor, and enforce their own administrative law
- **US Laws:**
 - **ECPA (Electronic Communication Privacy Act):** laws restricting government from putting wiretaps on phone calls and electronic communication in the form of data
 - **GLBA (Graham-Leach-Bliley Act):** aka *Financial Services Modernization Act of 1999*; allow banks to merge with insurance companies and financial institutions; customer account information is kept secure and private; customers may opt out of any information-sharing arrangements from bank/insurer
 - **SOX (Sarbanes-Oxley Act):** transparency in publicly traded corporation's financial activities; includes provisions for securing data and expressly names the traits of CIA; US legislation enacted to protect shareholders and the public from enterprise accounting errors and fraudulent practices
 - **HIPAA (Health Insurance Portability and Accountability Act):** protect patient records and data; known as ePHI
 - **FERPA (Family Educational Rights and Privacy Act):** prevent academic institutions from sharing student data with anyone other than parents or students (after age 18)
 - **DMCA (Digital Millennium Copyright Act):** provisions to protect owned data; cracking of access controls on copyrighted media a crime and enables holders to require any site to remove content

- **CLOUD Act (Clarifying Lawful Overseas Use of Data)**: allows US law enforcement and courts to compel American companies to disclose data stored in foreign data centers
- **FedRAMP**: not a law, but a US federal program that mandates standardized approach to security assessments, authorization, and continuous monitoring of cloud products/services; FedRAMP certification is required for cloud hosting services provided to a US government agency or contractor
- PII:
 - Direct Indicators: data elements that immediately reveal a specific individual; mobile phone number, IP address, SSN, birthday, home address, name; depends on jurisdiction
 - Indirect Indicators: characteristics/traits of an individual can reveal the identity of a person; not sensitive data but collect enough of it will reveal a person; location, birthplace, pets, industry, etc. Ex: a man born in Wisconsin, living in New Orleans, owns a dog, works in security
 - **Anonymization**: removing identifiers; certain jurisdictions, laws, and standards require this for both indirect/direct identifiers
- Federal PII law that complies with the EU Privacy Regulation: The EU, Australia, and New Zealand, Argentina, EFTA (Switzerland, Norway, Iceland, Lichtenstein), Israel, Japan, Canada; The USA does **NOT**; USA has an opt-out approach and EU has opt-in
 - **GDPR (General Data Protection Regulation)**: the EU's has the most significant and powerful privacy law in the world; describes handling of personal/private information of all EU citizens; codifies 7 principles:
 - Notice: individual must be informed about PII being gathered or created
 - Choice: individual can choose to disclose PII; need explicit agreement
 - Purpose: individual must be told specific use of information
 - Access: individual is allowed copies of PII
 - Integrity: individual is allowed to correct information
 - Security: entity holding PII is responsible for protecting PII and liable
 - Enforcement: entities holding PII understand they are subject to enforcement actions by EU authorities
 - **Privacy Shield**: program for American companies to comply with GDPR within the EU; voluntarily agree to comply; administered by the DoC (Department of Commerce) a federal enforcement entity in the US; companies must agree to auditing and enforcement with fines assessed for violations
 - **Data Subject**: individual whom PII refers; human being
 - **Data Controller**: entity collecting/creating PII; the cloud customer; responsible for any unauthorized disclosure of PII (with GDPR) regardless of fault
 - **Data Processor**: entity acting on behalf of data controller; performing any manipulation, storage, or transmission of PII; cloud service provider
 - **Cloud Carrier**: intermediary who provides connectivity and transport of cloud services between cloud providers and cloud consumers
 - Australian Privacy Act of 1988; Canada's PIPEDA (Personal Information Protection and Electronic Documents Act); EFTA and Switzerland; APEC (Asia-Pacific Economic Cooperation) Privacy Framework

- **ISMSs** (Information Security Management Systems): holistic overview of the entire security program within an org; detailed in ISO **27001**; provides a standardized international model for development and implementation of policies, procedures, and standards in a top-down approach in addressing and managing risk in an org
- **ISO/IEC 27017:2015**: set of standards regarding the guidelines for information security controls applicable to the provision and use of cloud services and customers; standard for providing cloud services and how customer information/privacy should be controlled
 - o **ISO/IEC 27018:2019**: focuses on code of practice and security techniques for processing PII in cloud services
- **Laws**: legal rules created by government entities/legislatures
- **Regulations**: rules created by governmental agencies
- **Standards**: dictate reasonable level of performance; created by an org (internal) or industry bodies/trade groups (external); following standards can reduce liability and compliance represents due care
- **eDiscovery**: process of identifying and obtaining electronic evidence for prosecutorial or litigation purposes; ISO 27050 is the industry standard and guidance
- **ISO Global Digital Forensic Standards**:
 - o ISO/IEC **27037**:2012: guide for collecting, identifying, and preserving electronic evidence
 - o ISO/IEC **27041**:2015: guide for incident investigation
 - o ISO/IEC **27042**:2015: guide for digital evidence analysis
 - o ISO/IEC **27043**:2015: incident investigation principles and processes
 - o ISO/IEC **27050-1**:2016: overview and principles for eDiscovery

Chapter 11 – Legal and Compliance Part II

- **KRIs (Key Risk Indicators)**: metrics used by an org to inform management of impending negative impact to operations; involves algorithms and rating systems ascribed to factors selected by analysts and management for an early-warning system; *forward-looking*, helps an org understand risks/events already occurred and impacted the business
 - o **KPIs (Key Performance Indicators)**: backward-looking; metrics to gauge business critical initiatives, objectives, or goals; measurable benchmarks against defined goals
- **Risk Appetite/Tolerance**: how the org views risks; senior management dictates the amount of risk an org is willing to take
- **Risk Profiles**: comprehensive analysis of the possible risks to the org; include a survey of various operations the org is engaged in, public perception, pending legislation, stability of countries where org operates
- **Physical Controls**: physical access to assets that reduces the impact of a physical event; locks, fire suppression, fences, guards
- **Technical Controls**: aka logical controls; controls that enhance the CIA triad; encryption, ACLs, audit trails, logs
- **Administrative Controls**: processes and activities that provide aspects of security; background checks, scheduled log reviews, mandatory vacations, robust/comprehensive security policies/procedures, designing business processes
- **Risk Management Framework (RMF)**:

- **ISO 31000:2018**: international standard focusing on design, implementing, and reviewing risk management processes and practices
- **NIST SP 800-37 (Guide for Implementing the RMF)**: a methodology for handling all organizational risk in a holistic, comprehensive, and continual manner; relies on automated solutions
- **ENISA (EU Agency for Network and Information Security)**: EU counterpart to NIST; standard and model developed in EU; responsible for producing Cloud Computing: Benefits, Risks, and Recommendations for Information Security; identifies top eight security risks based on likelihood and impact
- **COBIT**
- **ISO/IEC 31010:2009**: RM techniques
- **Risk Management Metrics**:
 - 5 – Critical; 4 – High; 3 – Moderate; 2 – Low; 1 – Minimal
- **ISO/IEC 15408-1:2009 (Common Criteria Assurance Framework)**: provide assurances for security claims by vendors; assurance for security products customers purchase have been thoroughly tested by 3rd party testers and meets requirements
- **ISO 28000:2007**: applies to security controls in supply chains
- **CSA STAR (Security, Trust, and Assurance Registry)**: single consistent framework for evaluating cloud providers; registry of security controls provided; designed for users to assess cloud providers, security providers, and advisory and assessment service firms as part of their vendor management due diligence while choosing providers
 - **CCM (Cloud Controls Matrix)**: list of security controls and principles appropriate for cloud environment, cross-referenced to other control frameworks (COBIT, ISO, NIST, FedRAMP, PIPEDA); aids in selecting/implementing appropriate controls for regulatory frameworks; an inventory of cloud service security controls that are arranged into separate security domains
 - **CAIQ (Consensus Assessments Initiative Questionnaire)**: self-assessment by cloud providers, detailing evaluation of practice areas and control groups
 - **CSA STAR Program – Open Certification Framework**:
 - Level One: Self-Assessment: requires release and publication of due diligence assessment against CSA's CAIQ/CCM
 - Level Two: CSA STAR Attestation: requires release and publication of available results of assessment from 3rd party based on CSA CCM and ISO 27001:2013 or AICPA SOC 2
 - Level Three: CSA STAR Continuous Monitoring: requires release and publication of results of continuous monitoring by certified 3rd party

ETC:

- **PKI**: framework of programs, procedures, communication protocols, and public key cryptography that enables a diverse group of individuals to communicate securely
- **OWASP (Open Web Application Security Project)**: an international nonprofit that focuses on identifying software vulnerabilities and educating developers in the practice of secure coding
 - Broken Access Control; Cryptographic Failures; Injection; Insecure Design; Security Misconfiguration; Vulnerable and Outdated Components; Identification and

Authentication Failures; Software and Data Integrity Failures; Security Logging and Monitoring Failures; Server-Side Request Forgery (SSRF)

- Joint Operating Agreements: provide nearby relocation sites so disruption is limited to the org's own facility/campus and can be addressed at a different location
- OSI Model: Physical; Data Link; Network; Transport; Session; Presentation; Application (**Please Do Not Throw Sausage Pizza Away**)
- SSO: allows a user to access multiple *applications* with a single set of credentials for authentication and authorization
- **Cross-Certification Model**: every participating org has to review and approve every other org; does not scale well
- **FPE (Format-Preserving Encryption)**: technique used to scramble contents of data using mathematical algorithm while keeping the structural arrangement of the data
- Logging Levels: OFF > FATAL > ERROR > WARN > INFO > DEBUG > TRACE > ALL
 - o OFF: used to turn off logging
 - o FATAL: application is about to stop a serious problem/corruption; the situation is catastrophic; application is unable to connect to the data store
 - o ERROR: inability to access a service/file; failure of something important in the application; when a severe issue is stopping functions within the application from operating efficiently, will continue to run but will need to be addressed
 - o WARN: detected an unexpected application problem
 - o INFO: normal behavior of applications
 - o DEBUG: diagnostic information in a detailed manner; fetch information to diagnose, troubleshoot, or test an application
 - o TRACE: captures all details about behavior of application; used when you need to see events within application and what happened in 3rd party libraries; use to query parameters in the code or interpret algorithm's steps
 - o ALL: shows all or customized logged defined
- **Management Plane**: technology that allows an admin to remotely manage a fleet of servers; logical infrastructure design used to configure cloud resources; launching VMs or configuring virtual networks
- **Information Commissioner**: responsible for enforcing UK's GDPR and offering advice and assistance to both the council and individual groups whose information is being held
- **NIS Directive** (EU2016/1148): first piece of EU-wide cybersecurity legislation; must notify competent authorities or CSIRT
- **NIST 800-145**: The NIST definition of Cloud Computing; a model for enabling ubiquitous, convenient, on-demand network access to a shared pool of configurable computing resources (e.g., networks, servers, storage, applications, and services) that can be rapidly provisioned and released with minimal management effort or service provider interaction.
- **NIST 800-146**: document reprises the NIST-established definition of cloud computing, describes cloud computing benefits and open issues, presents an overview of major classes of cloud technology, and provides guidelines and recommendations on how organizations should consider the relative opportunities and risks of cloud computing.
- **Functional requirements**: Those performance aspects of a device, process, or employee that are necessary for the business task to be accomplished. Example: A salesperson in the field must be able to connect to the organization's network remotely.

- **Nonfunctional requirements:** Those aspects of a device, process, or employee that are not necessary for accomplishing a business task but are desired or expected. Example: The salesperson's remote connection must be secure
- **DFD (Data Flow Diagrams):** useful in systems/software engineering to establish functional requirements before selection of technology takes place
- **Eucalyptus:** computer software building AWS-compatible private/hybrid cloud computing environment; multitenancy
- **ISO/IEC 17788:** overview of cloud computing and a set of terms and definitions
- **NIST 500-292:** adoption of cloud computing into the Federal Government
- **Metastructure:** protocols and mechanisms that provide the interface between the infrastructure layer and other layers; the glue that ties technologies between management and configuration
- **PRE (Proxy Re-Encryption):** allows a proxy (3rd party) to convert a ciphertext encrypted under one key into an encryption of the same message under another key; place as little trust and reveal as little information to the proxy to allow it to perform its translations
- **Software-Defined Infrastructure:** technical computing infrastructure entirely under the control of software with no operator or human intervention
- **Chaos Engineering:** method of testing software that deliberately introduces failure and faulty scenarios to verify resilience
- **Microsoft's (SDL) Security Development Lifecycle:** software development process based on the spiral model; help developers create applications/software while reducing security issues, resolving security vulnerabilities, and reducing development and maintenance costs; training, requirements, design, implementation, verification, release, response
- NIST 800-92: log management
- NIST 800-40: enterprise patch management planning
- Backup Types:
 - o Full
 - o Copy
 - o Differential: all data changed since last full backup; if a full back up was done on a Sunday, a differential backup will be done on Monday for only the files that changed since Sunday, Tuesday you back up only files that changed since Sunday (adding); quicker than a full backup but storage space will be used until another full back up is done
 - o Incremental: backs up data that changed since last backup; time consuming to restore data